

arsnova.eu

Security Hardening



Vier Wochen bis keine offenen HIGH-Befunde
und bestandene Security- und 500-NAT-Lasttests

Drei Gates entscheiden über die Freigabe

Eine Sicherheitsnote ist kein Abnahmekriterium. Messbare Ergebnisse sind es.

0

offene HIGH-Befunde

Node · PDF/SSRF · Public Creates

100 %

definierte Security-Tests

Rebind · Spoofing · Soft-Cap · Isolation

500

Clients hinter einer IP

Join · Vote · WS · Reconnect · Abuse

Release nur, wenn alle drei Gates grün sind – nicht, wenn der Kalender Woche 4 erreicht.

Danach: gezielter Penetrationstest mit Serverzugriff und Logs. Er ergänzt die Fixes; er ersetzt sie nicht.

Vier Leitplanken bestimmen jede Umsetzung

Sicherheit muss das accountfreie Produkt schützen, nicht in ein anderes Produkt verwandeln.

Accountfrei

Keine Login-Pflicht.

Capabilities bleiben das Besitzmodell für Host, Historie und Sync.

Hörsaal-NAT

Bis zu 500 Geräte teilen eine öffentliche IP.

Teilnehmerpfade erhalten keine engen IP-Limits.

Lokaler Nginx

Ein Proxy-Hop auf demselben Host, kein separates CDN/WAF.

TRUST_PROXY_HOPS=1.

Live vor Batch

Join, Vote und WebSocket haben Vorrang vor PDF, Upload und anderen teuren Host-Funktionen.

Nicht verhandelbar: Ein einzelnes Gerät darf über die gemeinsame IP niemals den ganzen Saal sperren.

Drei HIGHS müssen zuerst geschlossen werden

Die übrigen Befunde werden parallel gehärtet, solange sie die HIGH-Slices nicht blockieren.

Prio	Angriffsfläche	Mögliche Folge	Primärer Slice
HIGH	PDF-Bilder / Chromium	SSRF · Speicher/CPU-DoS · lokaler Zugriff	W0.2/W0.5 · W1.2 · W2.1
HIGH	Öffentliche Create-Endpunkte	PostgreSQL/Redis füllen · Dienststörung	W0.1 · W1.3/W1.6
HIGH	Node.js 20 EOL	Keine regulären Runtime-Security-Updates	W0.3 · W1.1
MED-H	Yjs / y-websocket	Link-Leak · Manipulation · WS-/Speicher-Missbrauch	W2.2/W2.3 · W3.4
MED	Proxy-Header / IP-Lockout	Limit-Bypass oder Saal-Sperre	W1.4/W1.5
MED	Container / --no-sandbox	Großer Blast-Radius nach Compromise	W2.1
MED	CSP / CORS	Schwacher XSS-Schutz · Cross-Origin-Missbrauch	W2.4/W2.5
MED	Legacy accessProof	Historie/Bonus/PDF rekonstruierbar	W3.3
MED	Backups gleicher Host	Hostverlust / Ransomware	W3.6

Limits folgen Identität und Kosten – nicht der IP

Teilnehmerverkehr wird fair verteilt; teure Serverfunktionen werden über harte Ressourcenbudgets geschützt.

Vorgang	Limitierung nach	Ausdrücklich nicht nach
Gültiger Join	Sessionkapazität + anonyme Client-ID	enger öffentlicher IP-Bucket
Ungültiger Code	Client-ID + globales Soft-Cap: Delay + Alert	Saal-Hard-Lock
Vote / Q&A / Blitzlicht	Teilnehmer-/Voter-ID + Session + Runde	IP
WebSocket	Teilnehmer + Session + globale Kapazität	limit_conn pro Hörsaal-IP
Quiz-Upload	Browser/Host + Payload + globales Budget	primär IP
PDF-Erstellung	Host-Token + Session + globale Parallelität	IP
Admin / Session Create	Progressive Delay + großzügiges globales Limit	enger Participant-IP-Lock
IP allgemein	Logs, Telemetrie, selten grobe Host-Grenzen	Teilnehmer-Authentifizierung

Vier Wochen, parallel nach Risiko und Abhängigkeit

W0 enthält sofortige Eindämmung; Woche 1 schließt den HIGH-Kern.

	W0	W1	W2	W3–4	Abnahme
Runtime & API	Body limits	Node + Creates		Astro 7	
PDF	Cap / Interim	SSRF core	Sandbox/Worker	Proxy / Queue	Tests
NAT & Realtime		IP + Soft-Cap	WS/Yjs A	Sync B	500-NAT
Browser & API policy			CSP RO / CORS		Smoke
Operations	Metrics			Backup/Alerts	Restore

Parallelisieren ja. Abhängigkeiten überspringen nein. Jede Zelle wird als eigener PR-Slice geplant.

W0 reduziert das Risiko noch vor dem Umbau

Diese Maßnahmen können sofort starten und liefern zugleich Messdaten für die Folgeslices.

ID	Jetzt implementieren	Done when	Rollback / Fallback
W0.1	Body-/Payload-Limits an Create, Upload und Export	Übergroß → 413; normale Classroom-Quizze unter Caps	Config-Revert; Caps nur mit Messdaten erhöhen
W0.2	PDF global auf 1–2 Jobs begrenzen	Aktive Jobs ≤ Cap; Live-Voting unverändert	Queue aus / klare Ablehnung statt ungecappter Jobs
W0.3	Node-24-Branch und CI-Matrix starten	Build/Smoke dokumentiert; Blocker sichtbar	Node 22 als datiertes Interim, nie zurück auf 20
W0.4	Create/PDF/WS/429-Schwellen sichtbar machen	Dashboard vorhanden; On-Call kennt die Ansicht	Alert zunächst informativ statt blind blockierend
W0.5	Optional: externe PDF-Bilder fail-closed	Kein unkontrollierter Egress; Host sieht Platzhalter	Nach W1.2/W3.1 Feature-Flag zurücknehmen

Erster Merge-Blocker: W0.1 und W0.2 brauchen Grenzwerte, Testfälle und Metriken im selben PR.

W1 schließt Runtime- und Create-Risiken

Drei getrennte PRs halten Rollback und Review überschaubar.

W1.1 · Runtime

Implementierung

- Builder + Production auf Node 24
- Node-20-Pfad entfernen
- .nvmrc und Docs angleichen

Akzeptanz

- Image baut und startet
- Smoke + relevante Tests grün
- Bei Node 22: Ticket + fixes Datum für 24

W1.3 · Public Creates

Implementierung

- Rate-Limits: quiz.upload / quickFeedback.create
- Zod .max() für Fragen und Optionen
- Payload-Cap
- Cleanup verwaister Uploads

Akzeptanz

- Abuse-Test gedrosselt
- normale Quizze unter Caps

W1.6 · Admin/Create

Implementierung

- grobe globale Budgets
- progressive Verzögerung
- Teilnehmerpfade unangetastet

Akzeptanz

- Create-Spam begrenzt
- Admin-Brute-Force erschwert
- kein enger Hörsaal-IP-Bucket

Vorgeschlagene Owner-Rollen: Platform · Backend/API · Backend/Auth

PDF-Fetches werden an die geprüfte IP gebunden

URL-Prüfung ohne Verbindungsbindung bleibt anfällig für DNS-Rebinding und TOCTOU.

01

Protokoll

Nur http/https; keine file-, data- oder fremden Schemes.

02

Redirect

Manuell, kleines Hop-Limit; jeden Hop vollständig neu prüfen.

03

DNS

Alle A/AAAA-Adressen normalisieren und klassifizieren.

04

Connect

Socket/Dispatcher an eine zuvor validierte Ziel-IP binden.

05

Netzgrenze

Private, Loopback, Link-local, Multicast, Doku-Netze und Metadata blockieren; Egress-Regel ergänzen.

06

Antwort

Timeout + Stream-Cap; keine Cookies/Auth/Proxy-Header; MIME + Magic-Bytes.

07

Assets

resolve() + Root-Containment; Traversal und Encodings testen.

Done when: Rebind-, Redirect-, Size-, Header-, MIME-, file://-, RFC1918- und Metadata-Tests sind grün.

Rate-Limits dürfen den Hörsaal nie gemeinsam sperren

Die Client-ID verbessert Fairness, ist aber kein Besitz- oder Sicherheitsnachweis.

Vorher: IP-Lock

Ein Gerät produziert
Fehlversuche.

Die gemeinsame Campus-IP
erreicht den Grenzwert.

500 legitime Clients werden
mitgesperrt.



Nachher: gestufte Budgets

Gültige Joins
Session + Client-ID

Ungültige Codes
Client-ID + globales Soft-Cap

Soft-Cap
Delay + Alert, kein Hard-Lock

Implementierungsschecks

- Backend nutzt nur req.ip
- CF-/True-Client-IP ignorieren
- Nginx überschreibt XFF
- gültige Joins nie im Fail-Budget
- IP nur Telemetrie/grob
- Soft-Cap-Auslastung als Metrik

Test: zwei Clients derselben IP blockieren sich nicht; Enumeration wird langsamer und löst Alarm aus.

Chromium: Sandbox nachweisen oder Worker isolieren

Non-root und cap_drop schließen den Befund nur, wenn --no-sandbox tatsächlich verschwindet oder der Worker isoliert ist.

Entscheidungsfaktor	Option A · Sandbox im App-Container	Option B · separater PDF-Worker
Nachweis	Chromium läuft ohne --no-sandbox; CI/Staging-PDF grün	Eigener Prozess/Container; enges Interface und Egress
Pflichtkontrollen	non-root · cap_drop · no-new-privileges	zusätzlich read-only rootfs · tmpfs /tmp · pids/CPU/RAM
Risiko	Sandbox kann mit Alpine/Capabilities kollidieren	Mehr Deployment- und Queue-Komplexität
Entscheidungsregel	Nehmen, wenn Sandbox reproduzierbar nachgewiesen wird	Default, wenn Sandbox nur mit --no-sandbox oder breiten Rechten läuft

Entscheidung bis Ende W1. Owner dokumentiert Threat Boundary, Egress-Regel, Limits und Rollback im W2.1-Ticket.

Realtime bleibt Local-First – aber mit Budgets

Relay-Härtung erfolgt in zwei Slices; Login und kurze Token-TTLs bleiben außerhalb des Designs.

Slice A · W2

Yjs-Relay

- Conn-/Payload-/Rate-Grenzen
- Room- und globale Budgets
- Ressourcenmessung

Konzept

- ADR für signierte Share-Tokens
- manuelle Rotation

Gate

Local-First-Smoke grün

Live-WS · W2

- max. Verbindungen pro Participant-ID
- großzügiges Session-Budget
- globale Serverkapazität
- Message-Size und -Rate
- zufälliger Reconnect-Jitter

Gate

95 % von 500 Clients in 30 s
reconnecten

Slice B · W3

- signierte Sync-Tokens
- UI: „Sync-Link ungültig machen“
- lange Gültigkeit
- alte Links nach Rotation tot

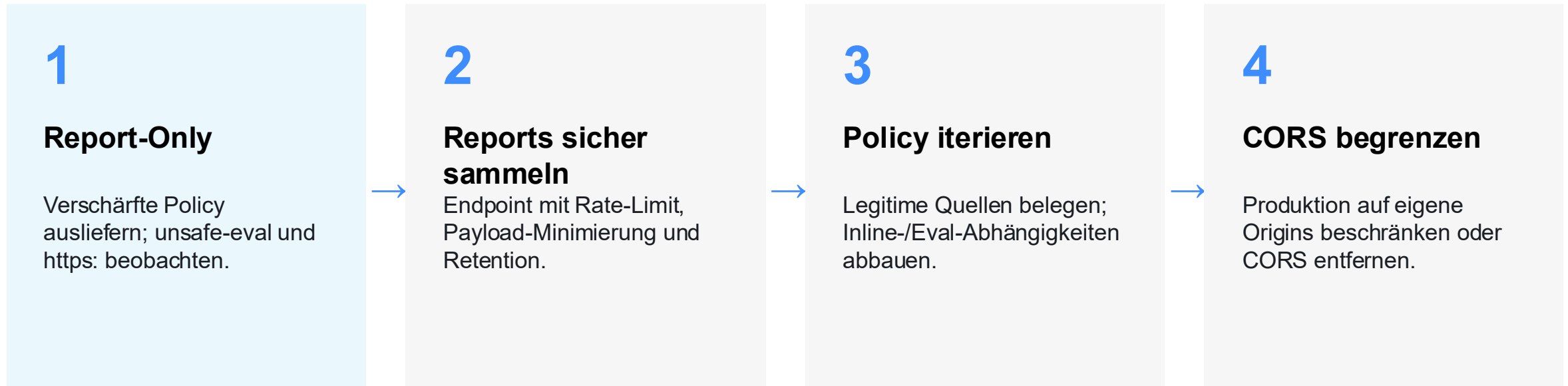
Nicht tun

- Kurz-TTL
- erzwungene Re-Auth
- kompletter Umbau in einem PR

Die Raum-UUID bleibt eine Capability. Sicherheit entsteht durch Limits, Signatur und Rotation – nicht durch ein Nutzerkonto.

CSP wird beobachtet, bevor sie blockiert

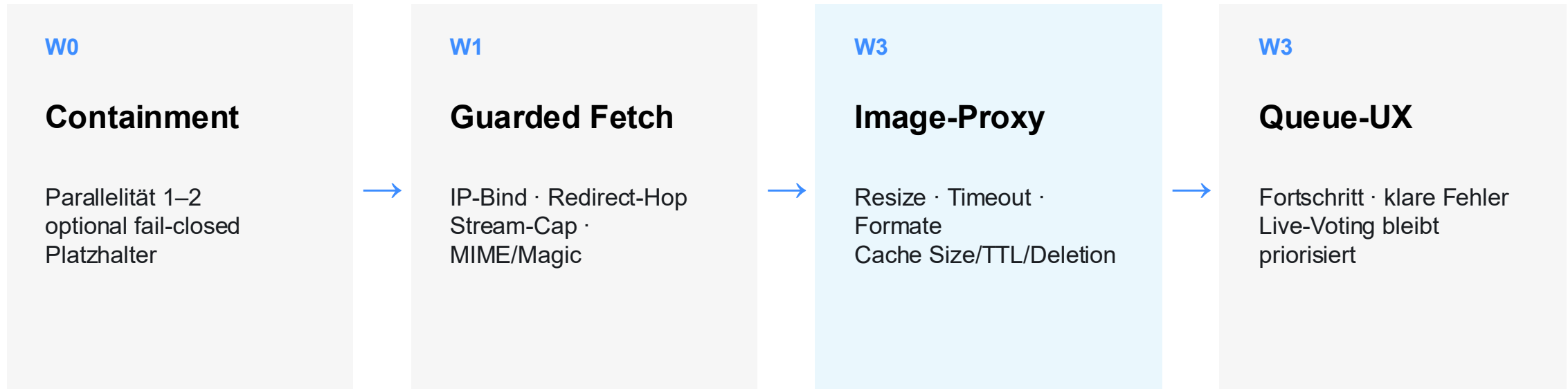
Eine harte Policy ohne Telemetrie kann die gesamte App leeren; Report-Only macht den Umbau messbar.



Enforce ist ein eigener späterer Cutover. Voraussetzung: Report-Auswertung, Smoke-Test und sofortiger Config-Rollback.

Der sichere PDF-Pfad bewahrt Bildfragen

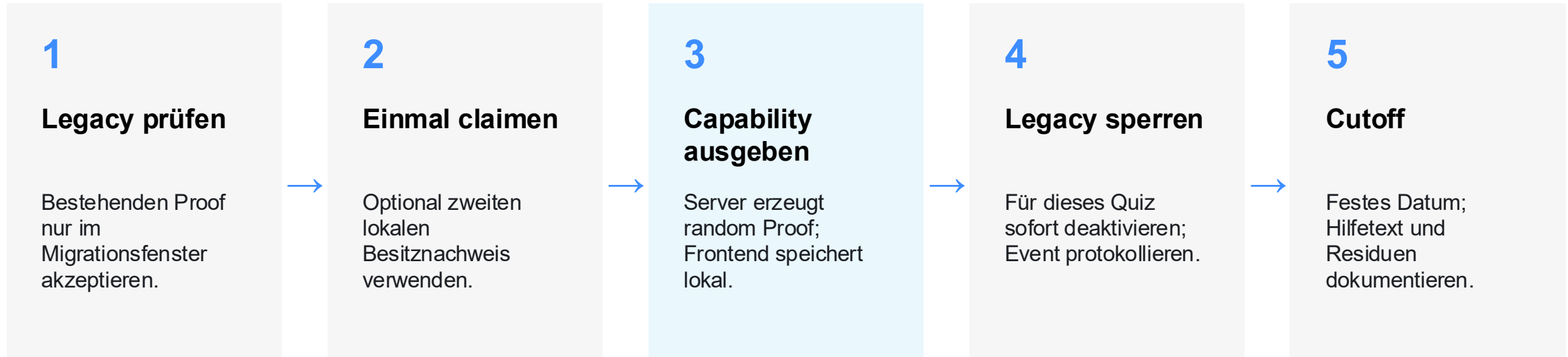
Der dauerhafte Zielzustand ist ein sicherer Proxy; der Platzhalter ist nur ein kontrolliertes Interim.



Cache-Regel: maximale Größe + kurze TTL + sitzungs-/exportgebundene Löschung. Keine PDF- oder Bilddaten über die Session-Lebensdauer hinaus.

Legacy-Zugriff endet über ein kontrolliertes Fenster

Die Migration ist bewusst Claim-first: Nutzbarkeit bleibt, das Residualrisiko wird zeitlich begrenzt.



Residualrisiko: Wer Quizinhalt und ID kennt, kann im offenen Fenster zuerst claimen. Dieses Risiko gehört in SECURITY-OVERVIEW und Betriebshinweis.

W3 macht Betrieb und Hygiene überprüfbar

Dauerhafte Sicherheit braucht Rotation, unterstützte Builds, Wiederherstellung und getestete Alarme.

W3.4 · Sync-Rotation

Signierte Tokens + UI zum Ungültigmachen. Alte Links nach Rotation tot; lange TTL bewahrt Offline/Reconnect.

W3.5 · Astro 7

Landing auf Astro ≥ 7.1 ; Build und axe grün. Security-Deps kontrolliert schließen, kein npm audit fix --force.

W3.6 · Backups

RPO, RTO, Retention und Key-Verantwortung festlegen. Verschlüsselt extern sichern; Restore auf isoliertem Ziel üben.

W3.7 · Monitoring

Create-Rate, PDF-Queue, WS-Connections, 429-Muster und Soft-Cap messen. Alarmweg und Runbook einmal real testen.

Abhängigkeiten bestimmen die PR-Reihenfolge

Kleine Slices erlauben einen sauberen Rollback und verhindern, dass Sync, PDF und Runtime in einem Risikopaket landen.

Kette	Warum diese Reihenfolge	PR-Schnitt
W0.5 → W1.2 → W3.1	Interim stoppt Egress; Guarded Fetch schließt HIGH; Proxy verbessert UX	Feature-Flag · Fetch-Library · Proxy/Cache getrennt
W0.2 → W3.2	Harter Cap schützt sofort; Queue und Fortschritt folgen später	Server-Cap vor UI/Cache
W2.2 → W3.4	Relay-Limits und ADR vor Token-/Rotationsimplementierung	Slice A: Limits/Konzept · Slice B: Tokens/UI
W1.4 + W1.5 → Lasttest	IP-Vertrauen und Soft-Cap müssen vor NAT-Abnahme stabil sein	Resolver-PR · Lockout-PR · dann Lasttest
W2.1 → PDF-Abuse-Test	Isolation und Ressourcenlimits müssen unter Angriffslast messbar sein	Deploy-Härtung separat vom PDF-Code
W2.4 → CSP Enforce	Reports belegen die spätere Policy; Enforce bleibt eigener Cutover	Report-Only · Auswertung · später Config-Cutover

Regel: Ein PR darf genau einen klaren Threat Case schließen und besitzt einen eigenen Rollback.

Jeder PR erhält einen überprüfbaren Liefervertrag

Owner, Risiko, Tests und Rückweg werden vor Implementierungsbeginn sichtbar gemacht.

Vor dem Coding

- Owner als Person/Rolle
- Ticket / Issue
- Abhängigkeiten und Reihenfolge
- Threat Case + erwartete Wirkung
- Rollback: Flag, Image-Pin, Config-Revert oder Cutover-Stop

Im PR

- Negativ- und Bypass-Tests
- Metrik/Alarm für das neue Budget
- klare Fehlermeldung / UX-Fallback
- Docs und Environment aktualisieren
- keine stillen neuen IP-Limits

Im Review

- Bypass-Pfad erklären
- Verhalten bei 500 gleicher IP prüfen
- Failure Mode und Ressourcenverbrauch prüfen
- Migration und Cache-Lebensdauer prüfen
- Rollback einmal trocken durchgehen

Merge-Gate

- CI/Smoke grün
- Security-Akzeptanz grün
- relevante Lastschwelle grün
- Dashboard zeigt Wirkung
- Owner bestätigt Rollback und Betriebsnotiz

Security-Tests zielen auf Bypässe

Happy-Path-Tests beweisen nicht, dass ein Guard gegen Rebinding, Encoding oder Header-Spoofing hält.

Kontrolle	Angriffstest	Erwartung	Gate
SSRF / Redirect	Ziel redirectet auf RFC1918, Loopback oder Metadata	Request vor Verbindung abgebrochen	W1.2
DNS-Rebind	DNS ändert Antwort zwischen Prüfung und Connect	Connect bleibt an validierte IP gebunden	W1.2
Stream / MIME	Chunked Oversize; falscher MIME; Nicht-Bild mit Bild-Endung	Cap während Stream; MIME + Magic blocken	W1.2
Asset-Pfad	../, encoded separators, Double-Encoding	resolve() bleibt unter Asset-Root	W1.2
IP-Spoof	CF-/True-/XFF-Header frei setzen	Bucket basiert nur auf req.ip	W1.4
Soft-Cap	IDs rotieren und Codes raten	Delay + Alert; gültige Joins bleiben offen	W1.5
Isolation/CSP	PDF-Ressourcenlimit und CSP-Report-Flood	Worker begrenzt; Reports gedrosselt/minimiert	W2.1/2.4

Testbeweise gehören ins Ticket: Testname, erwartete Blockstelle, beobachtete Metrik und Log -Auszug ohne sensible Daten.

500 Clients hinter einer IP sind das Release-Gate

Produkt-SLOs für Join, Vote und WS werden vor dem Lauf schriftlich festgelegt.

500

gleiche Quell-IP

distinkte Client-IDs · kein
Saal-Lock

95 %

Reconnect in 30 s

zufälliger Jitter · keine Conn-
Explosion

500

Votes im Burst

p95 und Fehlerquote
innerhalb SLO

1–2

PDF-Jobs parallel

Vote-Latenz nicht über
Schwelle

01

Baseline

02

Join/WS

03

Reconnect

04

Vote-Burst

05

Abuse parallel

06

Recovery

Pass: keine engen Participant-IP-429s, Kernsession innerhalb SLO, Metriken sichtbar, Rückkehr in Steady-State ohne ungeplanten Neustart.

Diese Abkürzungen sind ausdrücklich ausgeschlossen

Sie erzeugen entweder einen Hörsaal-Ausfall, brechen Produktversprechen oder verschieben Risiko nur scheinbar.

Würde den Hörsaal brechen

- × enge IP-Lockouts / limit_conn pro IP
- × globales Fail-Budget blockiert gültige Joins
- × Client-ID als Authentifizierung behandeln
- × Accounts „nur kurz“ einführen
- × sehr kurze Yjs-TTLs / erzwungene Re-Auth
- × Legacy-Zugriff abrupt ohne Fenster abschalten

Würde Security nur vortäuschen

- × Chromium dauerhaft mit --no-sandbox
- × npm audit fix --force
- × Astro-Advisories ohne Major-Story einzeln schließen
- × OWASP Dependency-Check zusätzlich als PR-Gate
- × ZAP sofort als blockierendes PR-Gate
- × CSP sofort enforce
- × externe PDF-Bilder dauerhaft abschalten

Review-Frage bei jeder vermeintlich schnellen Lösung: Welchen Angriff stoppt sie – und kann sie 500 legitime Clients gemeinsam treffen?

Jetzt starten: die nächsten 48 Stunden

Das Team verlässt den Termin mit benannten Ownern, offenen Tickets und zwei sofort mergebaren Containment-PRs.

- 01 Owner für Platform/Node, PDF, Backend/API, Realtime und QA/Performance benennen.
- 02 Node-Ziel entscheiden: 24 direkt – oder 22 nur mit datiertem Node-24-Cutover.
- 03 W0.1 Body-Caps und W0.2 PDF-Parallelität als getrennte PRs öffnen.
- 04 W0.5 entscheiden: externe Bilder bis W1.2 per Feature-Flag fail-closed?
- 05 W1.2 Owner und Design-Review für DNS-Bind, Redirects und Egress terminieren.
- 06 Produkt-SLOs und Lasttestumgebung für 500-NAT-Abnahme schriftlich festlegen.
- 07 Dashboard für Create, PDF, WS, 429 und Soft-Cap bereitstellen.

Definition des Zielzustands: keine offenen HIGHs · Security-Tests grün · 500-NAT-Lasttest grün · Rollbacks dokumentiert.

Anhang: Code- und Dokument-Landkarte

Code-Pointer beziehen sich auf den Review-Stand; beim Ticket-Schnitt auf aktuelle Pfade prüfen.

Domäne	Code / Dokument	Relevante Slices
PDF	apps/backend/src/lib/session-results-report-pdf.ts libs/session-export-report/...images.util.ts session-export-asset-reader.ts	W0.2/W0.5 · W1.2 · W2.1 · W3.1/3.2
Creates	apps/backend/src/routers/quiz.ts apps/backend/src/routers/quickFeedback.ts libs/shared-types Zod-Schemas	W0.1 · W1.3/W1.6
IP / Rate-Limit	apps/backend/src/trpc.ts apps/backend/src/lib/rateLimit.ts ENVIRONMENT.md	W1.4/W1.5
Runtime/Deploy	Dockerfile · Compose/Deploy-Docs deployment-debian-root-server.md	W0.3 · W1.1 · W2.1 · W3.6
Sync	Story 1.6c · architecture/quiz-library-sync.md ADR-0019	W2.2/W2.3 · W3.4
Historie/Landing	createLegacyQuizHistoryAccessProof Story 0.9 Astro ≥7.1	W3.3 · W3.5
Abnahme	LASTTEST-500-TEILNEHMENDE.md PERFORMANCE-TESTING.md · SECURITY-OVERVIEW.md	Security- und Last-Gates

Quelle: Sicherheits-Härtungsplan arsnova.eu, Stand 22.07.2026.